

Week 6: BattleOps Modules

Objective: Ship software at scale with airtight guardrails, signed artifacts, reproducible builds, policy-driven pipelines, and hardened internal platforms.

MONDAY: Enterprise CI/CD Security & Hardened Pipelines

Critical Concepts

- Least-privilege CI/CD architecture (OIDC > static credentials)
- Pipeline supply-chain risks (compromise, dependency poisoning)
- Secure workspace isolation (ephemeral runners/sandboxing)
- Terraform pipeline security patterns (plan-only vs apply stages)
- Secrets rotation automation (SOPS + GitHub OIDC + Vault)
- Pipeline break-glass mechanisms
- Attestation generation (build provenance metadata)

Key Outcomes

- Design a CI/CD system where:
 - No long-lived credentials exist
 - All pipeline steps are signed, reproducible, and auditable
 - Terraform cannot mutate infra without approval
 - All pipeline outputs produce **attestations** used by admission controls

THE DEVOPS WAR ROOM

TUESDAY: Image Security: SBOMs, Signing, Attestations, Policy Enforcement

Critical Concepts

- SLSA Level 3–4 supply-chain requirements
- Sigstore ecosystem:
 - Cosign (signing + verification)
 - Rekor (transparency log)
 - Fulcio (cert authority for tooling)
- Mandatory SBOM generation at build-time
- Admission policies:
 - Verify image signatures
 - Verify SBOM availability
 - Block untrusted registries

Key Outcomes

- Every image built in CI is:
 - Signed (cosign)
 - SBOM-attached (Syft/Grype)
 - Recorded in transparency logs
 - Audited for vulnerabilities
- Kubernetes only allows signed images from your registry (OPA/Gatekeeper/Kyverno rule)

THE DEVOPS WAR ROOM

WEDNESDAY: GitOps Governance: Multi-Environment Workflows & Drift Control

Critical Concepts

- Multi-layer GitOps (App Repo → Infra Repo → Cluster Repo)
- Progressive delivery with ArgoCD:
 - Sync waves
 - Rejecting partial rollouts
 - Out-of-sync remediation strategies
- Policy enforcement in GitOps (OPA + ArgoCD Policy Engine)
- GitOps anti-patterns (kubectl exec, manual rollbacks, namespace sprawl)
- Drift caused by autoscalers, operators, and CRDs

Key Outcomes

- Ability to design a GitOps system with:
 - Zero manual kubectl privilege
 - Multi-region deployment trees
 - Automated rollback on failed health checks
 - Guardrails that block misconfigured YAML without pipelines



THURSDAY: Platform Engineering: Golden Paths, Scorecards, Guardrails, Self-Service

Critical Concepts

- Golden paths as productized workflows
- Backstage + Scaffolder + Scorecards for enterprise standardization
- Enforcing platform SLAs for:
 - onboarding
 - deployment readiness
 - production certification
- Automated runtime compliance reports
- Metrics: developer friction index, path adoption score
- Self-service infra with Terraform + ArgoCD integration

Key Outcomes

- Build an internal platform where:
 - New services guarantee CI, CD, SLOs, SBOM, and scanning
 - Developers generate boilerplates that are already compliant
 - Scorecards enforce production readiness before shipping
 - Infra resources (DBs, namespaces, clusters) are auto-provisioned safely



FRIDAY: Enterprise DevSecOps + Policy + Runtime Guardrails

Critical Concepts

- Runtime policy engines (Kyverno, OPA, Gatekeeper)
- Compliance-as-code (CIS Benchmarks, NIST, SOC2)
- Preventing production drift + unauthorized manifests
- Workload security:
 - Non-root enforcement
 - ReadOnly root filesystem
 - Mandatory resource limits
 - Mandatory network policies
- Implementing **Zero Trust** in CI → CD → Runtime

Key Outcomes

- You can architect a **zero-trust Kubernetes environment** where:
 - Every workload must be signed
 - Every workload has resource limits, networks, liveness & readiness probes
 - Unapproved images or missing SBOM are blocked before scheduling
 - GitOps enforces compliance continuously
 - Any deviation triggers alerts + auto-reconciliation

